

Training Day 9 Report

Date: 25 June 2025

Module Name: Social Engineering & Targeted Reconnaissance

Mode: Theoretical + Practical

Main Focus of the Module

Day 10 focused on **social engineering techniques**—the psychological manipulation of individuals into divulging confidential information or granting access. Alongside the theory, we used advanced tools like **FOCA** and **Subfinder** to extract sensitive metadata and subdomains. The day concluded with a basic scan of a deliberately vulnerable site: <https://testphp.vulweb.com>.

Topics Covered

Social Engineering – Theory & Tactics

Definition:

Social engineering is the art of manipulating people into performing actions or revealing confidential information, rather than hacking systems directly.

Types of Social Engineering Attacks:

1. **Phishing:**
 - Fake emails/websites mimicking legitimate ones to steal data
 - Example: Fake Facebook login page
2. **Pretexting:**
 - Creating a fabricated scenario to trick the victim
 - Example: Impersonating IT support
3. **Baiting:**
 - Using physical or digital "bait" like infected USBs or free downloads
4. **Tailgating (Piggybacking):**
 - Gaining unauthorized access by following an authorized person into a secure area
5. **Quid Pro Quo:**
 - Exchanging something for information (e.g., free service for login details)

Human Behavioral Vulnerabilities:

- Trust
- Fear
- Curiosity
- Urgency
- Ignorance of cybersecurity practices

FOCA (Fingerprinting Organizations with Collected Archives)

Purpose: Extract metadata from public documents to gather intel

Use Case:

- Uploaded or linked PDFs, Word files on websites often contain author names, software versions, internal paths

Steps:

1. Install FOCA (Windows GUI tool)
 2. Scan a domain like `facebook.com` or `target.org`
 3. Download public documents
 4. Extract metadata such as usernames, server paths, software info
-

Subfinder (by ProjectDiscovery)

Purpose: Subdomain enumeration via passive online sources

Installation:

```
bash
Copy code
go install -v github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest
```

Command Example:

```
bash
Copy code
subfinder -d facebook.com
```

Result:

- Discovered multiple subdomains like `developers.facebook.com`, `ads.facebook.com`, etc.
-

Scanning `https://testphp.vulweb.com`

This is a **deliberately vulnerable** website used for testing scanning tools and exploiting known vulnerabilities.

Steps Taken:

1. Opened the URL in browser to explore login panels, admin pages
 2. Performed basic reconnaissance using:
 - Page source viewing
 - Manual path guessing (/admin, /robots.txt)
 - Basic vulnerability probing via Burp Suite
-

Key Takeaways

- **Social engineering is more about exploiting human flaws** than technical ones
- Tools like **FOCA** extract sensitive info from places organizations often overlook (documents)
- **Subfinder** is a fast, reliable passive subdomain enumeration tool
- Vulnerable sites like `testphp.vulweb.com` are safe environments to practice real scanning
- Defending against social engineering requires **training, awareness, and verification processes**